

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Target Application: Demo Web Application (v1.2.0)

Testing Date: July 27, 2026

Prepared By: Security Operations Team

EXECUTIVE SUMMARY

A security assessment was conducted on the target application to identify potential vulnerabilities. The assessment revealed multiple high and medium-severity security flaws that require immediate remediation to prevent unauthorized data access and system compromise.

VULNERABILITY FINDINGS

1. SQL Injection (SQLi)

CWE ID: CWE-89 | **Severity:** High | **Location:** /api/v1/login endpoint (username parameter)

Description: Improper neutralization of special elements used in an SQL command allows attackers to bypass authentication controls and extract database contents.

Remediation: Use parameterized queries, prepared statements, or ORM frameworks (such as SQLAlchemy) to safely handle user input.

2. Cross-Site Scripting (XSS)

CWE ID: CWE-79 | **Severity:** Medium | **Location:** /profile endpoint (bio parameter)

Description: The application does not properly validate or sanitize user input before reflecting it back in the response, allowing execution of malicious scripts in the victim's browser.

Remediation: Implement strict context-aware output encoding and sanitize all user-supplied input.

3. Broken Object Level Authorization (BOLA)

CWE ID: CWE-639 | **Severity:** High | **Location:** /reports/{id} endpoint

Description: The system fails to verify whether the currently authenticated user has permissions to access report objects belonging to other users.

Remediation: Implement robust server-side authorization checks verifying user ownership of requested records.